



THREAT ADVISORY

**ATTACK
REPORT**

**Threat Actors launch a campaign to exploit
vulnerability in Fortinet**

Date of Publication

October 27, 2022

Admiralty Code

B1

TA Number

TA2022236

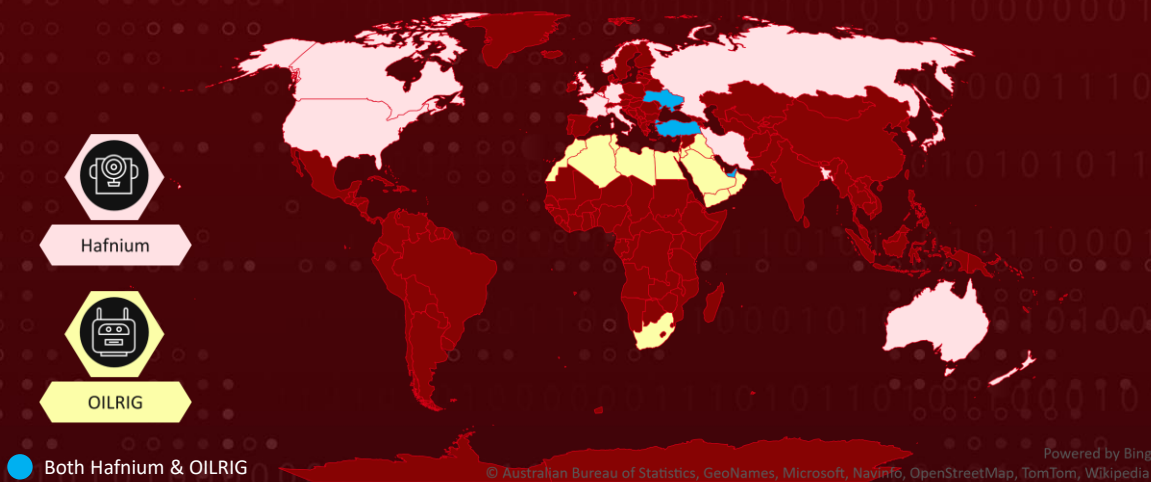
Summary

Tailgate campaign is currently being carried out by the threat actors Hafnium and OilRig. The goal of this campaign is to exploit vulnerabilities in Fortinet. Recently discovered vulnerability CVE-2022-40684, which has been attributed to Fortinet Products, is among the exploited vulnerabilities.

⚙️ CVE

CVE	NAME	PATCH
CVE-2022-40684	Authentication Bypass Vulnerability in Fortigate	✅

🗺️ Actors Map



⚙️ Potential MITRE ATT&CK TTPs

TA0004 Privilege Escalation	TA0005 Defense Evasion	T1548 Abuse Elevation Control Mechanism	T1548.002 Bypass User Account Control
T1068 Exploitation for Privilege Escalation			

Technical Details

Threat actors are already exploiting this Fortinet appliance vulnerability 15 days after an official patch was released. Hafnium and OilRig are among the threat actors behind this. These actors are seeking financial gains by exfiltrating sensitive information and stealing credentials to cause operations disruptions and reputational harm.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-40684	FortiOS: From 7.0.0 to 7.0.6 and from 7.2.0 to 7.2.1 FortiProxy: From 7.0.0 to 7.0.6 and 7.2.0 FortiSwitchManager: 7.0.0 and 7.2.0	cpe:2.3:o:fortinet:fortios:*:*:*:*:*:* cpe:2.3:o:fortinet:fortiproxy:*:*:*:*:*:* cpe:2.3:a:fortinet:fortiswitch_manager:7.2.0:*:*:*:*:*	CWE-288

Actors Detail

NAME	ORIGIN	TARGET LOCATIONS	TARGET INDUSTRIES
Hafnium (UNC2639, UNC2640, UNC2643, Ant)	China	USA, UK, Russia, Bangladesh, Belgium, Iran, Turkey, Norway, New Zealand, Germany, Canada, Australia, South Korea, Japan, Italy, France, UAE	Healthcare, Legal, NGO, Education
	MOTIVE		
	Information theft and espionage, Financial gain		

NAME	ORIGIN	TARGET LOCATIONS	TARGET INDUSTRIES
OilRig (Helminth, Clayslide, APT34, IRN2, COBALT GYPSY, ITG13, CHRYSENE, HEXANE, LYCEUM, HELIX KITTEN)	Iran	Oman, Azerbaijan, Bahrain, Iraq, Israel, Jordan, Kuwait, Lebanon, Mauritius, Qatar, Saudi Arabia, South Africa, Turkey, UAE, MENA region	Chemicals, Education, Energy, Financial (Finance), Government, Legal, Oil and Gas, Telecommunications
	MOTIVE		
	Information theft and espionage, Financial gain		

🔗 Patch Details

Upgrade to FortiOS version 7.07 or 7.2.2 or above

Upgrade to FortiProxy version 7.07 or 7.2.1 or above

Upgrade to FortiSwitchManager version 7.2.1 or above

🔗 References

<https://www.hivepro.com/vulnerability-in-fortinet-allows-authentication-bypass/>

<https://www.cyfirma.com/outofband/fortinet-authentication-bypass-vulnerability-exploited-by-threat-actors/>

<https://docs.fortinet.com/document/fortigate/7.0.7/fortios-release-notes/289806/resolved-issues>

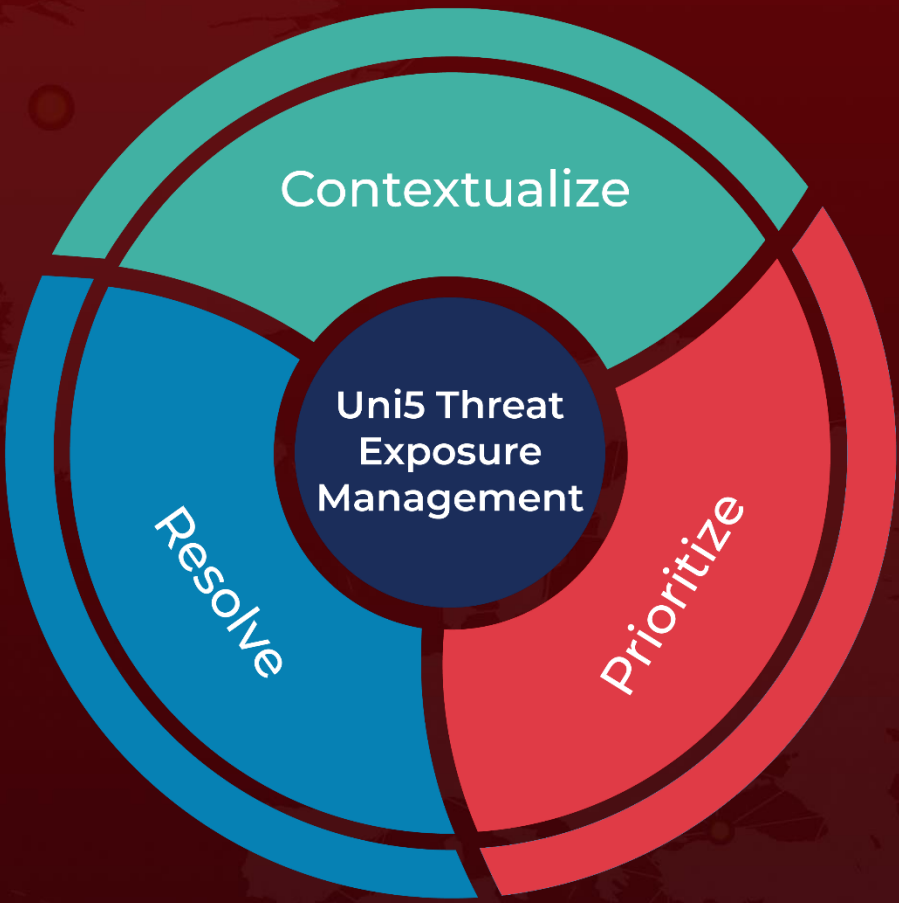
<https://www.rapid7.com/blog/post/2022/10/07/cve-2022-40684-remote-authentication-bypass-vulnerability-in-fortinet-firewalls-web-proxies/>

<https://portswigger.net/daily-swig/critical-authentication-bug-in-fortinet-products-actively-exploited-in-the-wild>

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

September 27, 2022 • 6:10 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com